

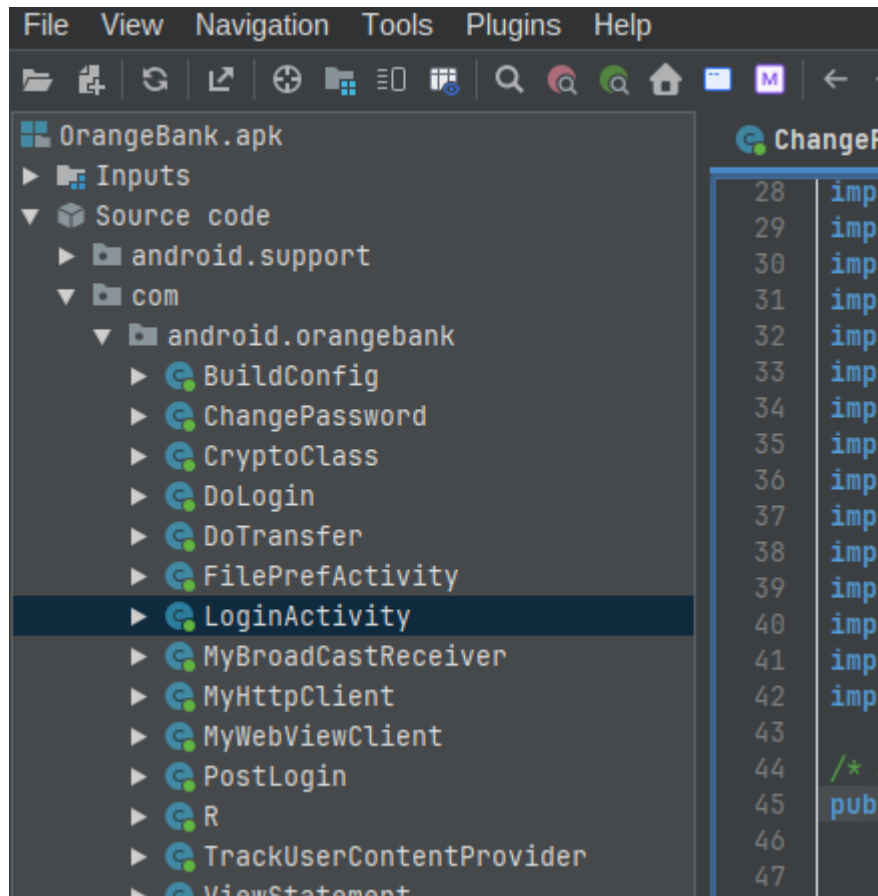
Title: Inadequate Code Obfuscation

Tech Overview: Obfuscation hinders the readability of code.

Instance: Android Manifest

Impact: Code can be read easily which saves an attacker time.

Screenshots



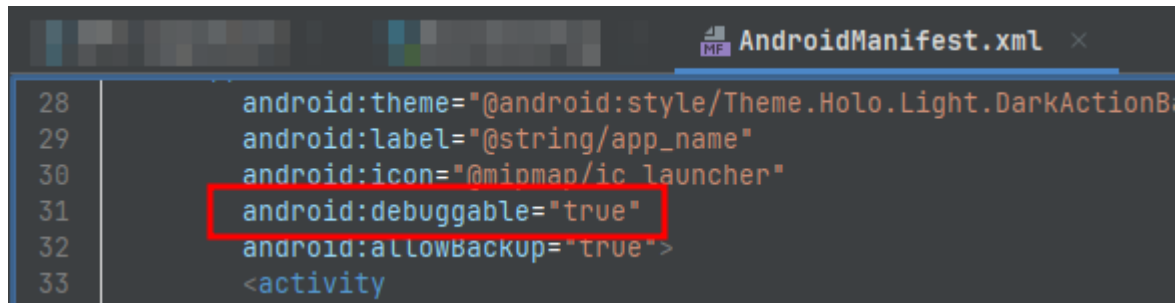
Title: Debuggable Flag Set To True

Tech Overview:

Instance: Android Manifest

Impact:

Screenshots



```
28     android:theme="@android:style/Theme.Holo.Light.DarkActionBar"
29     android:label="@string/app_name"
30     android:icon="@mipmap/ic_launcher"
31     android:debuggable="true"
32     android:allowBackup="true">
33     <activity
```

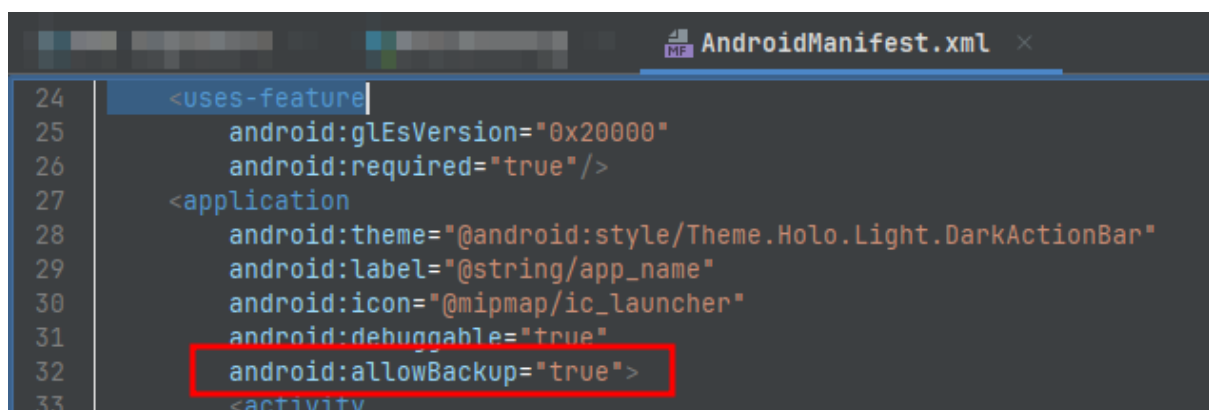
Title: Backup Flag Set To True

Tech Overview: Backups contain all data.

Instance: Android Manifest file.

Impact: With a backup an attacker can view confidential information related to the application.

Screenshots



```
24     <uses-feature
25         android:glEsVersion="0x00000000"
26         android:required="true"/>
27     <application
28         android:theme="@android:style/Theme.Holo.Light.DarkActionBar"
29         android:label="@string/app_name"
30         android:icon="@mipmap/ic_launcher"
31         android:debuggable="true"
32         android:allowBackup="true">
33     <activity
```

Title: Hard Coded Credentials

Tech Overview: Credentials stored in plaintext within the code.

Instance: DoLogin activity, MyHttpClient activity

Impact: Allowed an attacker to log in as dev admin.

Screenshots:

```
nameValuePairs.add(new BasicNameValuePair("password", DoLogin.th
if (DoLogin.this.username.equals("devadmin")) {
    httpPost2.setEntity(new UrlEncodedFormEntity(nameValuePairs)
    responseBody = httpClient.execute(httpPost2);
} else {
    httpPost.setEntity(new UrlEncodedFormEntity(nameValuePairs))
    responseBody = httpClient.execute(httpPost);
```

Request

Pretty Raw Hex

```
1 POST /devlogin HTTP/1.1
2 Content-Length: 27
3 Content-Type: application/x-www-form-urlencoded
4 Host: 10.2.25.102:8443
5 Connection: keep-alive
6
7 username=devadmin&password=
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 Content-Length: 54
4 Date: Thu, 12 Mar 2026 12:06:55 GMT
5 Server: localhost
6
7 {"message": "Correct Credentials", "user": "devadmin"}
```


Title: Unprotected Activities

Tech Overview: Allows unauthenticated access to different pages within the application.

Instance: Going from login page to postlogin page.

Impact

Screenshots

```
Gadget (run) on (Android: 15) [usb] # android intent launch_activity com.android.orangebank.PostLogin
(agent) Starting activity com.android.orangebank.PostLogin...
(agent) Activity successfully asked to start.

Gadget (run) on (Android: 15) [usb] # █
```

Title:

Tech Overview

Instance

Impact

Screenshots

```
(agent) [862046] Watching Keystore.load("java.io.InputStream", "[C")
(agent) [862046] Watching Keystore.getKey("java.lang.String", "[C")
(agent) Registering job 862046. Name: android-keystore-watch
(agent) [862046] Keystore.load(android.content.res.AssetManager$AssetInputStream@42aa9f5, P,a,s,s,w,0,r,d,1)
called, loading a BKS keystore.
(agent) [140675] Called SSLContext.init(), overriding TrustManager with empty one.
Gadget (run) on (Android: 15) [usb] # █
```